CONFIDENTIAL — INTERNAL

acumon

AI IN AUDIT · COMPLIANCE MEMORANDUM

AI Risk Management & Compliance

Import Options, Cloud Audit Connectors and AI-Populate — addressing the concerns raised by ICAEW and the FRC

DOCUMENT	DATE	PREPARED BY
Risk & Compliance Memo v1.0	7 May 2026	Acumon — Methodology & Engineering
AUDIENCE	**STATUS**	**CLASSIFICATION**
RI / Audit Compliance Partner; ICAEW QAD; FRC AQR	Issued for review	Confidential — Internal

AI Risk Management & Compliance Memo

A description of the AI-assisted features under development in worktree `confident-khayyam-dcd581`, the design controls that surround them, and how those controls map to the concerns raised by the ICAEW and the FRC for AI in audit work.

SCOPE	Import Options modal · Cloud Audit Connector registry · AI Extractor · Review & Apply flow · Current-Year AI Populate.
AUDIENCE	Firm RI / Audit Compliance Partner; ICAEW QAD inspection; FRC AQR inspection; engineering team owning the feature.
ANCHORS	ICAEW *Artificial intelligence in audit work: managing the risks*; FRC *Guidance on the use of AI in the audit of financial statements* (2025) and 2026 generative/agentic update; ISA (UK) 200, 220 (Revised), 230, 240, 315 (Revised), 500, 540; ISQM (UK) 1; UK GDPR / DPA 2018.

> **Foundational position.** The feature is positioned as **prefill, not audit evidence**. Nothing produced by the AI extractor or the Current-Year AI Populate flow is, on its own, sufficient appropriate audit evidence within the meaning of ISA (UK) 500. Auditors must obtain corroborating evidence in the normal way and exercise professional scepticism over every AI-suggested value.

CONTENTS

1. Summary of how the feature is designed to be safe
2. ICAEW concerns addressed
3. FRC concerns addressed
4. Residual risks and watch-items
5. Pointers for ICAEW QAD / FRC AQR inspection
6. Appendix — Code references
7. Sources / further reading

1. Summary of how the feature is designed to be safe

The table below is a quick map from each headline AI-in-audit risk theme to the concrete control implemented in this feature. Each control is referenced by its file in §6.

Risk theme	Design control in this feature
Automation bias / over-reliance	Two-stage flow: AI proposes → reviewer ticks/edits/deletes → only then is anything written. Every AI-written field is rendered with an **orange dashed surround** driven by `__fieldmeta`, so the reviewer can never lose sight of which numbers/text came from a model.
Hallucination	Extractor system prompt explicitly forbids fabrication ("DO NOT fabricate values. If a field is blank in the source, skip it."). Unparseable model output yields zero proposals. Temperature 0.1. The applier silently drops rows where `fieldKey` is missing.
Professional scepticism	The reviewer must positively approve each row before it lands. Excluded tabs (see below) cannot be auto-populated under any circumstance.
Critical judgements	Risk of Material Misstatement (`rmm`) and Trial Balance (`tb`) are hard-coded as `AI_POPULATE_EXCLUDED_TABS`. The applier double-filters in `FORBIDDEN_TABS` even if the prompt is bypassed.

Risk theme	Design control in this feature
Confidentiality / data leakage	Cloud-connector **credentials are never persisted** — only the connection recipe is stored. The Current-Year AI Populate endpoint sends only in-tool engagement data to the model; **no live web search**. Source text is truncated to 60 000 characters before being sent to the model to bound exposure.
Sufficient appropriate audit evidence	AI output is treated as a working-paper **prefill**, not as evidence. Tabs that hold the auditor's risk assessment and the trial balance are excluded. Walkthrough conclusions, test conclusions and RI sign-offs remain manual.
Documentation & traceability	Every populated field carries `__fieldmeta` ({source, byUserId, byUserName, at, sourceLocation}). The engagement's `importOptions.history` records `prompted`, `uploaded`, `cloud_fetched`, `extracted`, `applied`, `documents_copied`, `current_year_populated` events. Each extraction persists the raw model response and model name in `import_extraction_proposals`.
Governance & change control	Cloud connectors are firm-scoped, admin-owned, and the seeded MyWorkPapers entry is intentionally **empty** until a firm admin completes the recipe — the system refuses to invent endpoint paths it has not been given.

2. ICAEW concerns addressed

ICAEW's guidance for audit registered firms calls out a recognisable cluster of risks. Each is mapped below to the specific design control in the feature.

2.1 Automation bias

> *"The human tendency to believe that machine-made outputs are correct."*

How the feature responds.

- AI never writes directly to the engagement file. Outputs are surfaced in `ImportReviewModal.tsx` as proposals, with an explicit per-row checkbox / delete control. `applyProposals()` runs only on the rows the reviewer has not marked `deleted`.
- Populated fields are visually marked: `FieldProvenance.source` is `'prior_period_ai'` or `'current_year_ai'`, and the form components render the orange dashed surround whenever such a marker is present. The marker survives across sessions, so a later reviewer (manager / RI) is alerted that an AI-derived value sits behind the field.
- The marker is shed only when a human edits the value, ensuring professional judgement is recorded against any number that ends up in the final file.

2.2 Probabilistic / non-deterministic outputs (Generative AI)

ICAEW's guidance (and the FRC's 2026 update on generative and agentic AI) stresses that GenAI is probabilistic, and that for anything requiring deterministic numerical processing, a rules-based component is required alongside.

How the feature responds.

- Numerical work is **not** delegated to the model. The trial balance (`tb`) and Risk of Material Misstatement (`rmm`) tabs — which drive materiality calculations, sample sizes and risk responses — are excluded by `AI_POPULATE_EXCLUDED_TABS`.
- For PAR (Preliminary Analytical Review) rows, `applyParRows()` validates that the proposed value is numeric and rejects `NaN` rather than silently coercing.
- Materiality, fundamental tests, and substantive procedures continue to use the existing rules-based formula engine and schedule-action pipeline; the AI feature is layered on top of that engine, never inside it.

2.3 Loss of professional judgement / scepticism

- The `ImportReviewModal` is mandatory between extraction and apply. There is no "auto-apply" path.

- Conclusions and sign-offs are out of scope: the AI is not permitted to set walkthrough conclusions, test conclusions, RI matters, or final review fields.
- The reviewer's user identity is captured on every applied row (`buildProvenanceEntry`), making the chain of judgement reviewable downstream.

2.4 Confidentiality and data protection

ICAEW expects firms to consider whether client data leaves the engagement, and on what terms.

- **Credentials never persisted.** The Cloud Audit Connector record holds only the recipe; per-call credentials live only in memory for the duration of the request. There is no `password`, `token` or `client_secret` column on `cloud_audit_connectors`; migration `2026-05-07-import-options-and-cloud-connectors.sql` confirms this.
- **No live web search in AI Populate.** The Current-Year endpoint deliberately limits the model's input to the engagement's own data plus the prior-period engagement's permanent file. It does not call out to general web tools.
- **Bounded prompt.** Source content is truncated to 60 000 characters before being included in the model prompt, capping the volume of client data sent to the AI provider per call.
- **Firm scoping.** Engagement, connector and proposal access is gated by `session.user.firmId === engagement.firmId`; the Methodology Admin Cloud Connectors page is similarly firm-scoped.
- **Data residency / vendor disclosure.** The model used (`meta-llama/Llama-3.3-70B-Instruct-Turbo` via Together AI) is recorded against every extraction (`import_extraction_proposals.ai_model`) so the firm can evidence which sub-processor handled which engagement's data.

2.5 Explainability and auditability of AI outputs

- `import_extraction_proposals` persists the **raw model response** (`raw_ai_response`) and the **model identifier** (`ai_model`) for every extraction, so the firm can later reconstruct exactly what the model produced and why a given proposal landed.
- Each proposal carries a `sourceLocation` (e.g. `"Ethics > Independence > Q3"`) which the reviewer sees as hover text in the Review modal and which is stored back into `__fieldmeta.sourceLocation`. This satisfies the "why this value?" question on review.
- Proposals are kept after apply as an audit trail; new extractions are written as new rows rather than mutating existing ones (`status: 'pending' → 'applied' | 'cancelled'`).

2.6 Bias in training data and outputs

The feature is not a model-training pipeline — it consumes a third-party foundation model — so the firm cannot directly audit its training corpus. Mitigations:

- The AI is restricted to *suggesting destination + value* mappings from material the firm itself supplies. It is not asked to opine on accounting treatment, judgement areas, or going concern.
- Excluded tabs and "no-fabricate" prompt rules keep the model away from areas where bias would be most damaging (risk assessment, materiality).
- The `proposedValue` field is preserved verbatim alongside the user-edited value so a later reviewer can see if the model's output was systematically wrong in a particular dimension.

2.7 Skills, training, competence (ISA (UK) 220 / ISQM (UK) 1)

The firm's onboarding pack should be updated to cover:

- when each Import Options checkbox should be ticked, and what each does;
- that the orange dashed marker means "AI-prefilled — review with scepticism";
- that RMM and TB tabs are out of scope for AI population by design;
- that the AI is *not* audit evidence and corroboration is still required.

A pointer to this memo should be added to the firm's audit methodology manual and referenced in CPD records for staff using the tool.

2.8 Agentic AI risks

ICAEW (echoing the FRC 2026 generative/agentic update) flags that agents that *act* — not just suggest — amplify generative-AI risks. The feature in this worktree is deliberately **not agentic**:

- It does not call other systems autonomously.
- It does not iterate over its own outputs.
- It does not write to the engagement file without human review.
- The Current-Year AI Populate endpoint is a **one-shot, server-side** call that returns proposals and an apply summary; there is no loop.

If the firm later layers agent behaviour on top (e.g. "auto-attempt to clear outstanding matters"), this design must be re-reviewed against this memo and against the FRC's guardrails / human-in-the-loop expectations.

3. FRC concerns addressed

The FRC's 2025 guidance on AI in audit and its 2026 generative/agentic update raise a number of expectations of audit firms. Each is mapped below.

3.1 Quality management (ISQM (UK) 1)

The FRC expects AI to be brought inside the firm's quality management system, not run as a side-project.

- Cloud connector creation, edit, activation and deactivation flow through the **Methodology Admin** area (`components/methodology-admin/CloudAuditConnectorsAdmin.tsx`), which is gated to firm administrators. Connectors are firm-scoped (`firm_id` foreign key) and uniquely keyed `(firm_id, vendor_key)`.
- Built-in vendors (e.g. MyWorkPapers) are seeded as **stubs with empty endpoints**: `emptyMyWorkpapersConfig()` deliberately yields `baseUrl: ''` and `endpoints: {}`, with a `notes` field instructing the admin to complete the recipe before use. The runtime refuses to call out without a configured base URL.
- Activation toggles (`is_active`) allow the firm's quality team to disable a connector without deleting the recipe — useful where a vendor breach or a deprecation forces a pause.

3.2 Risk assessment of the AI tool itself

The FRC expects firms to risk-assess each AI tool before use and on a continuing basis. This memo, plus the populated `cloud_audit_connectors` and `import_extraction_proposals` tables, gives the firm the evidence base for that assessment:

- Each extraction's model identifier and raw response are retained, so the firm can sample outputs and assess accuracy / bias trends.
- The `importOptions.history` log on each engagement gives a per-engagement view; a firm-wide view can be obtained by joining `import_extraction_proposals` across engagements.
- The applier reports `applied`, `skipped` and `warnings` per call, written into `importOptions.history.note` (e.g. `applied=12, skipped=3, model=meta-llama/Llama-3.3-70B-Instruct-Turbo`). Skip and warning rates are an early indicator of model drift.

3.3 Sufficient appropriate audit evidence (ISA (UK) 500)

The FRC is explicit that AI output is **not** in itself audit evidence.

- The feature is **prefill**, not evidence. Documentation and conclusions reached on each tab still require the auditor to reference the underlying client document, system extract or third-party confirmation.
- The orange dashed surround is intended to remind the reviewer at the moment of sign-off that the value originated as an AI suggestion, prompting them to confirm the underlying evidence is on file.
- Excluded tabs (RMM and TB) keep the most evidence-sensitive areas — the trial balance the audit opinion attaches to, and the auditor's risk assessment — entirely out of the AI flow.

3.4 Documentation (ISA (UK) 230)

- The `__fieldmeta` provenance map satisfies ISA 230's requirement that working papers identify *who* did *what*, *when*, and *on what basis* — extended to "via what AI tool".

- `import_extraction_proposals` retains the raw AI response, supporting subsequent re-performance of the firm's review.
- `importOptions.history` provides an immutable engagement-level audit trail of when AI was used and with what result.

3.5 Professional scepticism (ISA (UK) 200 / 240)

- Mandatory human review of every proposal before apply.
- Visual marking of every AI-touched field, both at apply time and on every subsequent render.
- Hard-excluded tabs keep judgement-heavy areas out of the AI loop.

3.6 Confidentiality of client data (ISA (UK) 220 + UK GDPR)

- No persistence of cloud-connector credentials.
- No live web search in the AI populate flow.
- Truncation of source content before model submission.
- Firm-scoping of all data accessed by the feature (engagement, connector, proposal).

3.7 Cyber and access controls

- 2FA-verified session required (`session.user.twoFactorVerified`) before the AI Populate endpoint will run.
- Connector credentials cannot be exfiltrated from the database because they are not in the database.
- The OAuth2 client-credentials flow runs server-side only; tokens are never returned to the browser.

3.8 Vendor due diligence (third-party AI provider)

- Provider: Together AI. Model: `meta-llama/Llama-3.3-70B-Instruct-Turbo`. Both are recorded per extraction.
- The firm should hold Together AI's data-processing terms on file and confirm that submitted prompts are not used for model training. This memo flags that requirement; the contract review sits outside the tool.

3.9 Validation & continuing monitoring

- The `import_extraction_proposals.proposals` JSON, combined with the post-edit values in `__fieldmeta`, allows the firm to compare *what the AI proposed* against *what the auditor signed off on* — a natural validation dataset.
- Skip-rate and warning-rate from the applier should be reviewed at each cold-file review or annual methodology refresh.

3.10 Generative- and agentic-AI specific concerns (FRC May 2026)

- **Hallucination:** mitigated by the system prompt's explicit no-fabrication rule, low temperature (0.1), and the human review gate.
- **Probabilistic outputs:** confined to *suggesting* prefills; deterministic computations remain in the rules-based formula engine.
- **Agent autonomy:** out of scope — see §2.8.
- **Guardrails:** allow-list of tab keys passed in the prompt and re-checked server-side; forbidden-tab list applied before any database write; per-row `fieldKey` validation; non-numeric guard on PAR rows.

4. Residual risks and watch-items

#	Residual risk	Owner	Mitigation in flight / proposed
R1	A reviewer rubber-stamps AI proposals without checking source documents.	Engagement Partner / RI	Cold-file review programme tests that AI-marked fields trace to underlying evidence. Consider sampling 25% of AI-marked fields per cold review.
R2	Together AI's terms or location change unnoticed.	Firm Compliance	Annual sub-processor review; `import_extraction_proposals.ai_model` evidences which model handled which engagement.

#	Residual risk	Owner	Mitigation in flight / proposed
R3	An admin configures a connector pointing outside the firm's stated processing region.	Firm Admin / DPO	Add an admin-side warning when the configured `baseUrl` host is outside an allow-list. Recommended follow-up.
R4	The 60 000-character truncation could silently drop material data.	Engineering	Surface a warning in `ImportReviewModal` whenever the source was truncated. Recommended follow-up.
R5	A future change accidentally removes RMM/TB from the exclusion lists.	Engineering	Lock the exclusion list with a unit test that asserts both `'rmm'` and `'tb'` are present in `AI_POPULATE_EXCLUDED_TABS` and `FORBIDDEN_TABS`.
R6	Reviewer edits an AI-prefilled value and the orange marker is shed before the manager has reviewed.	Methodology	Manager review tab to expose a "show all AI-prefilled fields, including those subsequently edited" lens, sourced from `__fieldmeta` history.
R7	A prompt-injection string in a prior audit file persuades the model to step outside the allow-list.	Engineering	Defensive double-filter is already in place (`safeProposals` re-applies the exclusion list, and the applier re-applies `FORBIDDEN_TABS`). System-prompt-only mitigation is not treated as load-bearing.
R8	Agentic / autonomous extension layered on top without re-doing the AI risk assessment.	Director of Audit	Any agentic capability must trigger a refresh of this memo before it goes live. Add this commitment to the firm's AI policy.

5. Pointers for ICAEW QAD / FRC AQR inspection

If asked at inspection how the firm discharges its duties when AI is used in audit, this memo plus the artefacts below should be made available:

1. This memo (`docs/AI-Risk-Management-and-Compliance.md` / `.pdf`).
2. The firm's AI policy and CPD records covering the tool.
3. A query against `import_extraction_proposals` showing every AI-assisted engagement, the model used, and the apply / skip outcomes.
4. A query against any engagement's `importOptions.history` showing the lifecycle (`prompted → uploaded/cloud_fetched → extracted → applied / current_year_populated`).
5. A walkthrough of `__fieldmeta` on a sample engagement, demonstrating that AI-prefilled fields are visually flagged and individually attributable.
6. The Cloud Audit Connectors admin page (`/methodology-admin/cloud-audit-connectors`) showing recipe-only storage.
7. The Together AI / sub-processor due-diligence file.

6. Appendix — Code references

Concern	File
Excluded tabs (AI populate)	`lib/import-options/types.ts` · `AI_POPULATE_EXCLUDED_TABS`
Forbidden tabs (apply)	`lib/import-options/apply-proposals.ts` · `FORBIDDEN_TABS`
No-fabricate prompt	`lib/import-options/ai-extractor.ts` · `SYSTEM_PROMPT`
Provenance	`lib/import-options/types.ts (FieldProvenance, FieldMetaMap);` `lib/import-options/apply-proposals.ts (buildProvenanceEntry)`
Engagement-level audit log	`app/api/engagements/[engagementId]/ai-populate-current/route.ts` · `importOptions.history`

Concern	File
Cloud connector recipe-only storage	`prisma/migrations/manual/2026-05-07-import-options-and-cloud-connectors.sql; lib/import-options/cloud-fetch.ts`
Credential handling (in-memory only)	`lib/import-options/cloud-fetch.ts` · `buildAuthHeaders`
2FA gate on AI populate	`app/api/engagements/[engagementId]/ai-populate-current/route.ts`
In-tool data only (no live web)	`app/api/engagements/[engagementId]/ai-populate-current/route.ts` · `evidence pack construction`
Defensive double filter	`app/api/engagements/[engagementId]/ai-populate-current/route.ts` · `safeProposals`

7. Sources / further reading

- ICAEW — *Artificial intelligence in audit work: managing the risks* (audit-regulations-and-guidance area).
- ICAEW — *Managing the risks of AI* (technology / artificial-intelligence area).
- ICAEW — *FRC publishes landmark guidance on the uses of AI for audit* (Viewpoints, July 2025).
- ICAEW — *How helpful is FRC's guidance on generative and agentic AI?* (Viewpoints, May 2026).
- FRC — *Guidance on the use of Artificial Intelligence in the audit of financial statements* (2025) and 2026 update on generative and agentic AI.
- ISA (UK) 200, 220 (Revised), 230, 240, 315 (Revised), 500, 540; ISQM (UK) 1.
- UK GDPR / Data Protection Act 2018, in respect of any personal data inside client material processed by the AI extractor.

Prepared by the Acumon methodology & engineering team · v1.0 · 7 May 2026 · Confidential — Internal.